PROYECTO FINAL - DEVSECOPS

IAM Secure

Informe técnico

Gobierno y gestión centralizada
de identidades y accesos

Prueba-ProyectoFinal | Grupo 1 | DEVSECOPS2026_2

AUTORES

Oscar Daniel Acosta

David Enrique Diaz

Ingrid Tatiana Vesga

Jean Carlos Almenarez Ríos

Yeison Fabián Bernal López

ASIGNATURA

Seg en Entornos Cloud y Devops

14 de octubre de 2026 | America/Bogota

Corte de código: f87243e | Alcance académico y local

Tabla de contenido

Los títulos y números de página son enlaces internos. Las referencias identificadas como [R1]-[R13] enlazan las evidencias de origen.

1. Introducción 3

1.1 Contexto, problema y alcance . . . 3
1.2 Objetivos y metodología . . . 3
1.3 Corte técnico y límites . . . 3

2. Arquitectura y UML 4

2.1 Responsabilidades, datos y decisiones . . . 4
2.2 UML de componentes . . . 5
2.3 UML de despliegue y exposición . . . 6
2.4 UML de secuencia de autenticación . . . 7
2.5 UML de casos de uso e historia funcional . . . 8

3. Threat Dragon y STRIDE 9

3.1 Modelo de contexto y límites de confianza . . . 9
3.2 DFD nivel 1 y persistencia lógica . . . 10
3.3 Inventario STRIDE: T01-T10 . . . 11
3.4 Inventario STRIDE: T11-T20 . . . 12
3.5 Riesgo residual y tratamientos prioritarios . . . 13

4. Pipeline DevSecOps 14

4.1 Integración continua y políticas de bloqueo . . . 14
4.2 ZAP automatizado y Quality Gate Sonar . . . 15
4.3 Publicación y despliegue simulado . . . 16

5. Resultados y tabla de hallazgos 17

5.1 Resultados cuantitativos y procedencia . . . 17
5.2 Hallazgos de calidad y riesgos no aceptados . . . 18
5.3 Hallazgos de alcance y deuda de cierre . . . 19
5.4 Cobertura, integridad y evidencias consultadas . . . 20

6. Conclusiones 21

6.1 Balance técnico . . . 21
6.2 Cierre priorizado y alcance de la entrega . . . 21

1. Introducción

1.1 Contexto, problema y alcance

IAM Secure es una plataforma académica para centralizar identidades y accesos. Resuelve la administración de usuarios, credenciales, MFA, roles, compañías, sesiones y concesiones de vistas. El proyecto incorpora aprovisionamiento desde Excel y auditoría, y integra controles de seguridad en construcción, pruebas y despliegue [R1, R2].

La jerarquía separa ADMIN_TI, ADMIN_SOPORTE y líderes de Facturación, Logística y Gestión Humana. Las compañías delimitan el alcance de administración y consulta. Las tarjetas del portal son vistas académicas de referencia: no constituyen sistemas de facturación, logística o recursos humanos.

1.2 Objetivos y metodología

Objetivo general. Implementar y verificar una solución de identidad y acceso con autenticación reforzada, autorización en servidor y un ciclo DevSecOps trazable.

Objetivos específicos. Aplicar RBAC y alcance por compañía; permitir sesiones revocables y MFA obligatorio; procesar cargas XLSX con validación previa; conservar auditoría; modelar amenazas mediante Threat Dragon/STRIDE; y automatizar controles en GitHub Actions.

La evaluación contrasta código, diagramas, reportes versionados y ejecuciones identificadas. Cada cifra se atribuye a su commit, fecha y entorno. No se suman suites solapadas. El CI directo del espejo espera el Quality Gate de Sonar; el check externo confirma su aprobación.

1.3 Corte técnico y límites

Elemento	Corte utilizado
Código evaluado	f87243e en master del espejo. E29 conserva el análisis; esta edición documental incorpora su resultado.
CI del espejo	Run 38587861186: 31/31 trabajos aprobados y check externo Sonar aprobado.
ZAP final	Staging construido desde f87243e: GET-only, 7 scans y 39 operaciones/API-rol.
Sonar actual	Quality Gate passed. Cobertura nueva 88,1 % frente a 80 % mínimo; global 54,5 %. Periodo y umbrales preservados.
Evidencia histórica	Cobertura local, instalación limpia, publicación 1.0.0 y CD conservan sus cortes propios.

El informe no acredita producción real con TLS/HA ni ausencia global de vulnerabilidades. PostgreSQL es compartido; el conector Sync y las vistas de negocio mantienen alcance académico.

2. Arquitectura y UML

2.1 Responsabilidades, datos y decisiones

La solución utiliza React/Vite y Nginx para la interfaz, FastAPI/Python para APIs y PostgreSQL 17 para persistencia. Dos workers gestionan sincronización y entrega de auditoría. La carga Excel pertenece a Identity; la grilla reutiliza el frontend en un origen separado [R2].

Componente	Responsabilidad y relación
Identity	Autoridad de identidades, contraseña, MFA, JWT/sesiones, roles, compañías y carga Excel. Aprovisiona permisos iniciales del líder.
Permissions	Catálogo cerrado de nueve vistas; concesiones por usuario/compañía. Consulta /auth/me en Identity y vuelve a comprobar el alcance en PostgreSQL.
Frontend / grilla	Panel, portal, carga y administración de vistas. La grilla recibe una sesión temporal por un canal validado y la conserva en memoria.
Sync Worker	Reclama sync_jobs, reintenta y recupera trabajos; conector externo simulado.
Audit Dispatcher / Service	Outbox y entrega con token interno; persistencia sanitizada, idempotencia por event_uuid y protección append-only.
PostgreSQL	Identidad, organización, sesiones/MFA, colas, auditoría, permisos y lotes/filas Excel. Volumen persistente.

Las decisiones principales son autorización en servidor, sesiones persistentes revocables, separación de responsabilidades y outbox transaccional donde está implementado. La firma JWT por sí sola no concede acceso: se comprueban usuario, roles, compañía y sesión vigentes. Un permiso ausente o deshabilitado se deniega.

> **Límite arquitectónico**
>
> Los almacenes D1-D6 son particiones lógicas de una sola instancia PostgreSQL. No se afirma aislamiento físico de bases por microservicio. El uso de un usuario DB compartido con privilegios amplios conserva tratamiento pendiente en T04/T14.

2.2 UML de componentes

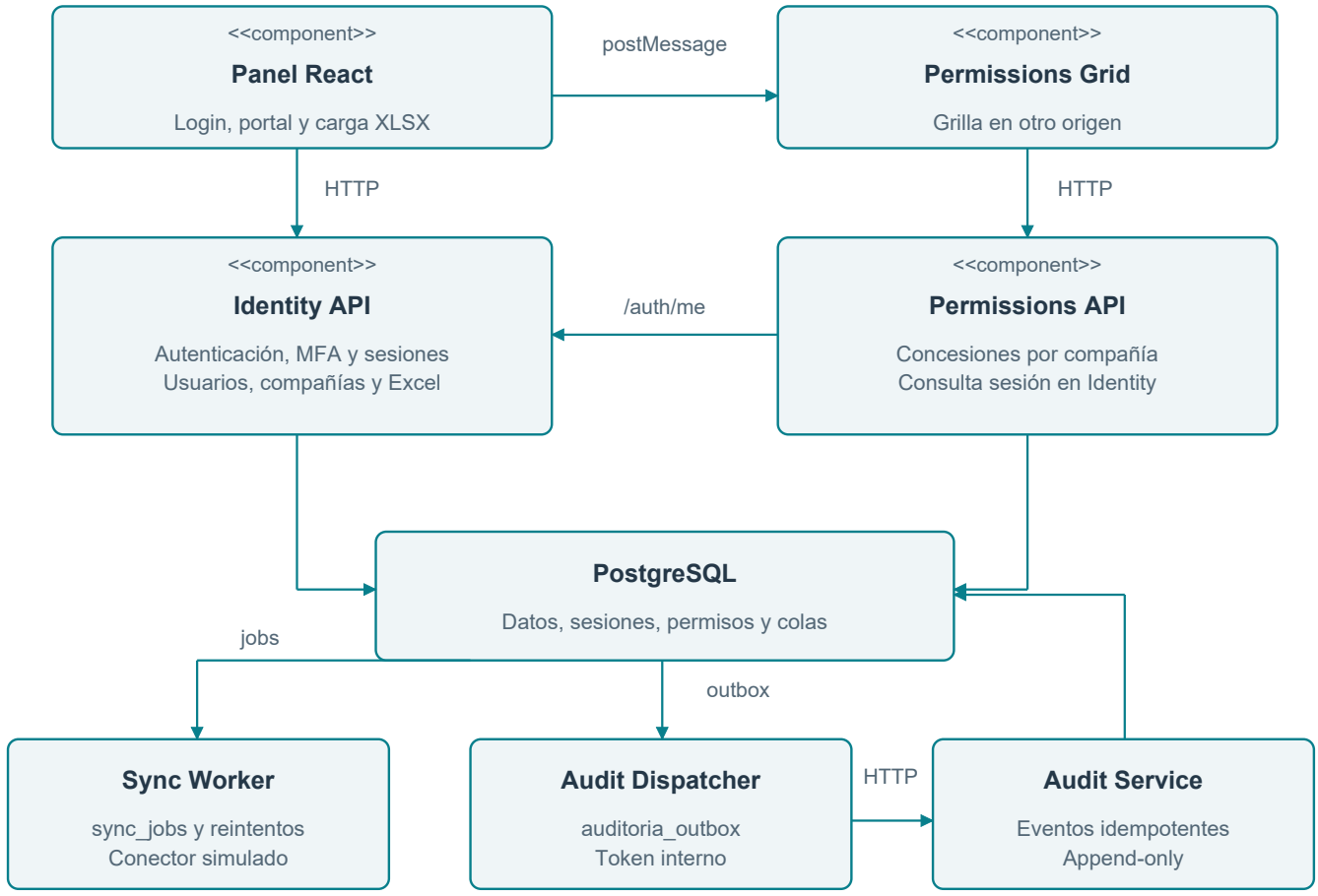


Figura 1. Vista UML de componentes simplificada para el informe. Fuente: COMPONENTES.md y arquitectura [R2]. Las flechas representan dependencias y flujos principales; no muestran todos los endpoints.

Identity mantiene la autoridad de autenticación; Permissions no replica el JWT_SECRET ni la clave de cifrado MFA. La comprobación online de sesión permite que revocar una sesión o retirar alcance tenga efecto sin esperar a la expiración criptográfica del token.

La creación individual y la carga Excel reutilizan el mismo aprovisionamiento. Los permisos iniciales se guardan con el usuario; los duplicados y reintentos no reactivan excepciones. SMTP está fuera de la transacción de PostgreSQL y no garantiza entrega exactamente una vez.

> **Auditoría y trabajo asíncrono**
>
> auditoria_outbox desacopla la entrega de eventos. Los workers usan estados persistidos, reclamo concurrente y recuperación. La atomicidad del evento de restablecimiento MFA en /auth permanece pendiente en T06.

2.3 UML de despliegue y exposición

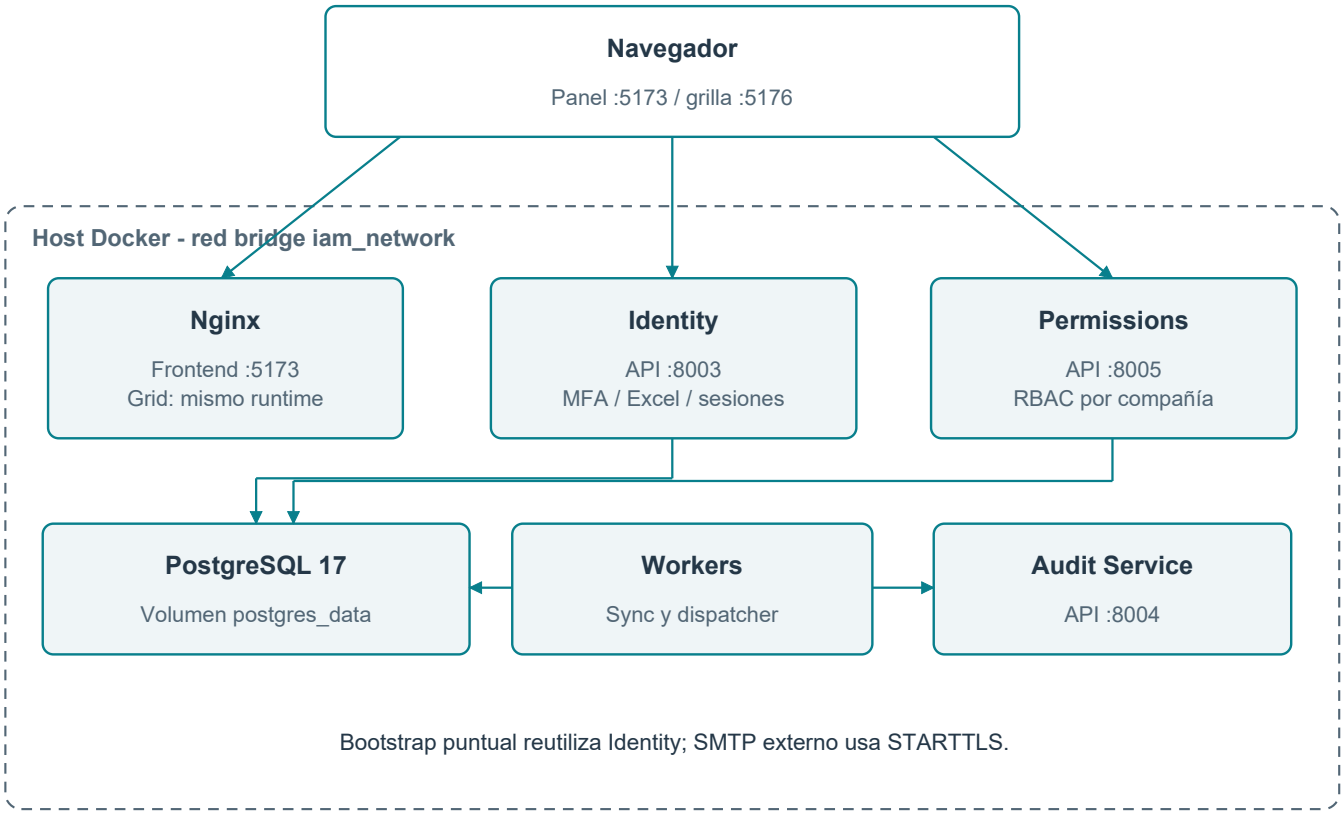


Figura 2. Despliegue local de desarrollo. Redibujo de DESPLIEGUE.md [R2]; no representa la topología de producción simulada del runner.

Servicio	Puerto host	Observación
Frontend / Identity	5173 / 8003	Publicación de desarrollo en host; sin TLS acreditado.
Permissions Grid / API	127.0.0.1:5176 / :8005	La grilla reutiliza Nginx/frontend; APIs conservan autorización.
Audit / PostgreSQL	127.0.0.1:8004 / 5433	PostgreSQL publica 5433 en desarrollo; volumen postgres_data.
Sync / dispatcher	Sin puerto host	Procesos Python; no requieren interfaz HTTP publicada.

El Compose local construye las aplicaciones desde fuente. Las imágenes Docker Hub 1.0.0 son una publicación histórica y no contienen todos los cambios posteriores. Git no transporta cuentas, secretos ni volúmenes.

2.4 UML de secuencia de autenticación

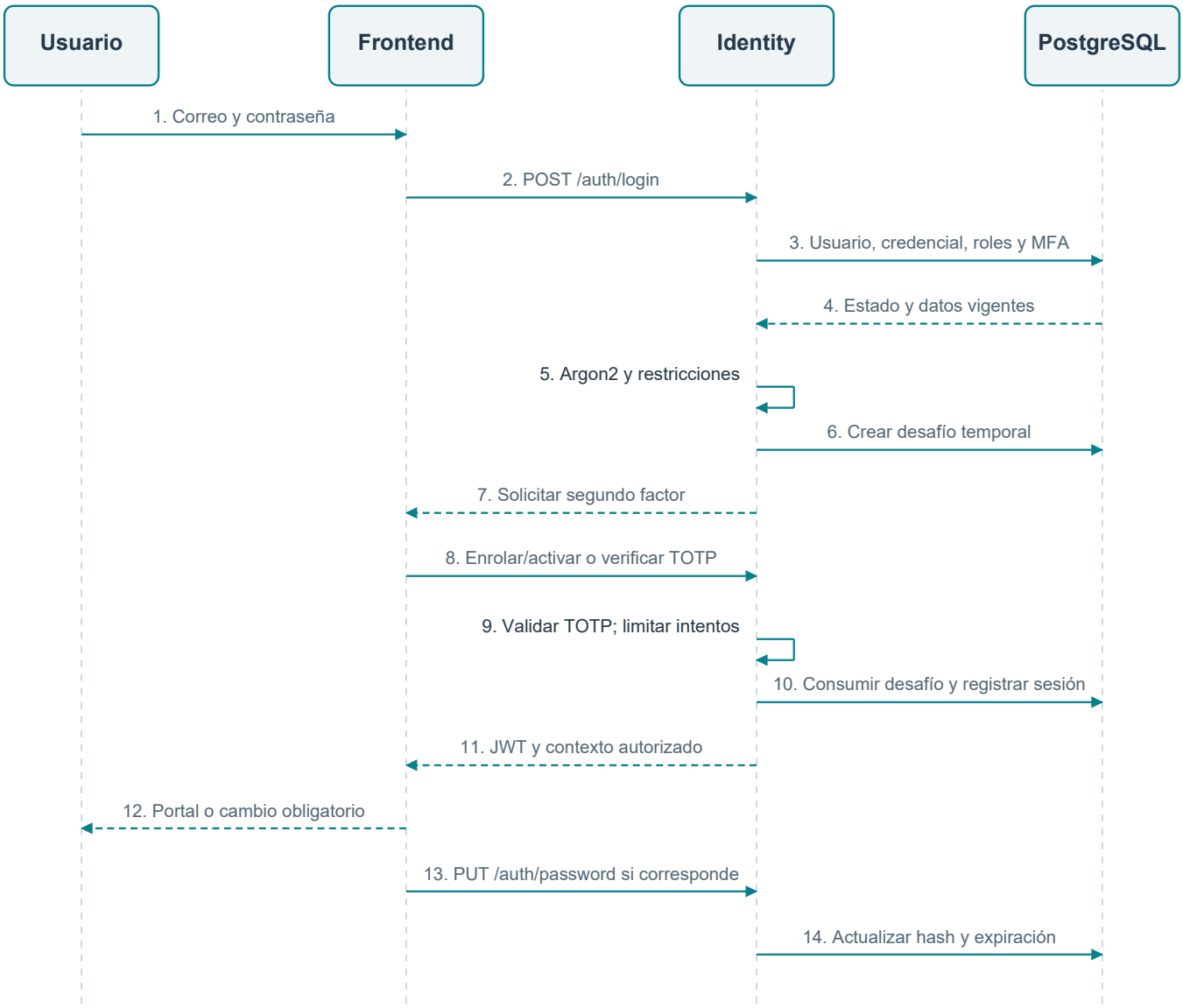


Figura 3. Secuencia resumida de primer factor, MFA, sesión y cambio obligatorio [R2]. La validación TOTP pertenece a Identity; el módulo MFA no se representa como microservicio independiente.

Con primer factor válido se crea un desafío aleatorio, con expiración, uso único e intentos limitados. Sin MFA activo se enrola y activa TOTP; con MFA activo se verifica el código. La sesión definitiva se emite después del segundo factor y se registra mediante jti en PostgreSQL.

Credenciales/estado inválidos, desafío expirado, TOTP incorrecto o falta de rol producen rechazo según el contrato. La sesión de contraseña temporal permanece restringida hasta completar el cambio. La inactividad predeterminada es de cinco minutos; frontend y API conservan comprobaciones propias.

2.5 UML de casos de uso e historia funcional

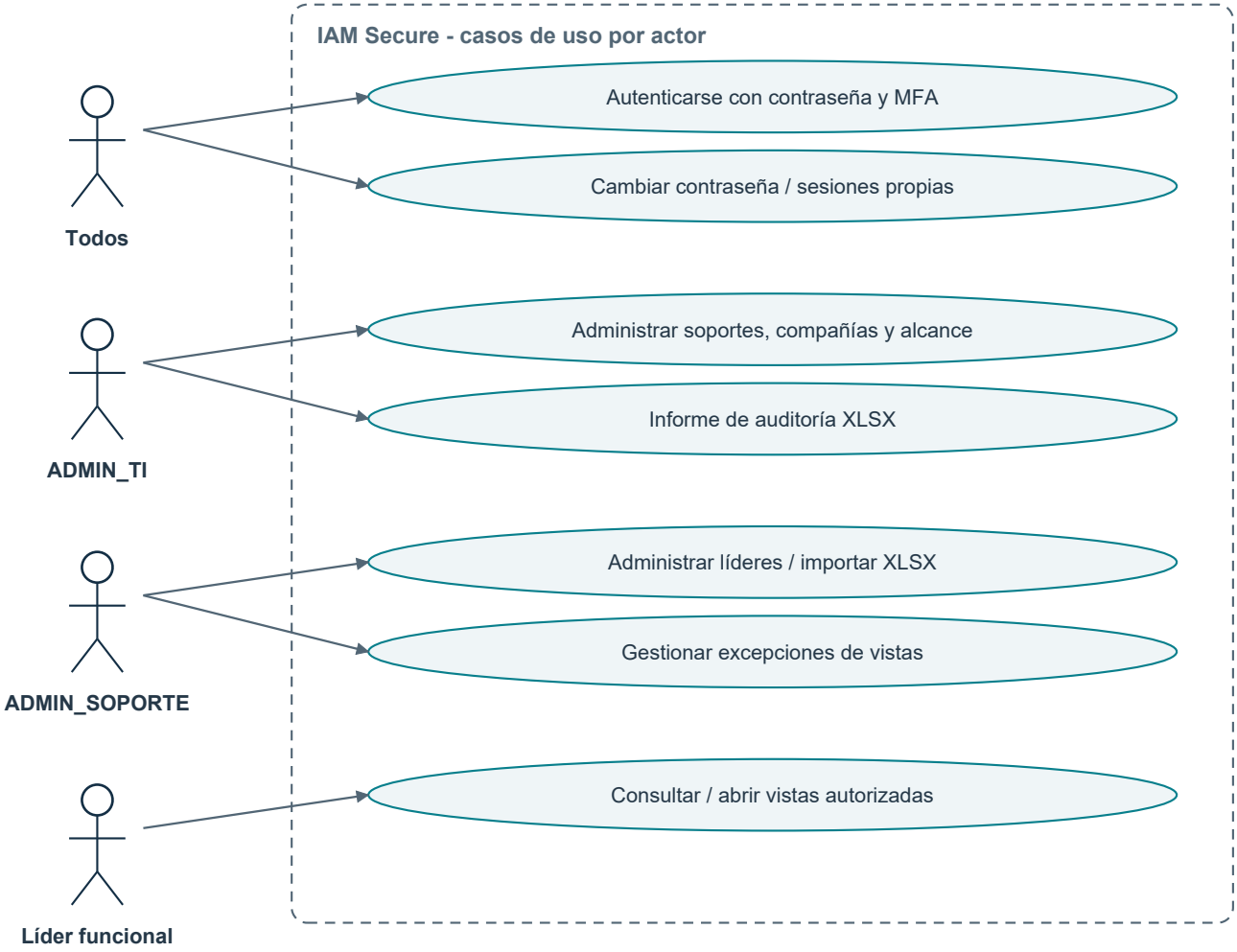


Figura 4. Casos de uso por actor, redibujados para lectura [R2]. Los líderes se distinguen por rol funcional y concesiones; un botón visible no sustituye autorización API.

Historia distinta de autenticación: ADMIN_SOPORTE valida un XLSX para una compañía activa asignada, confirma creación/envío, procesa filas válidas y exporta resultados. Después administra una excepción de vista desde la grilla y comprueba las opciones del líder. Revalidar un duplicado no modifica la cuenta ni reactiva permisos.

La validación previa no crea usuarios ni envía correo. La importación limita tamaño, filas y ZIP expandido; rechaza macros, fórmulas y vínculos externos según el parser. La ejecución por fila usa bloqueo y transacción, con estado persistido para consultar o retomar el lote.

El recorrido local aceptado utiliza una cuenta; ampliar varias filas con correos funcionales y preparar la presentación final son tareas distintas. Las pruebas CI con correo/API simulados no equivalen a SMTP real o un E2E completo.

3. Threat Dragon y STRIDE

3.1 Modelo de contexto y límites de confianza

Threat Dragon documenta el modelo as-is mediante DFD nivel 0 y 1 y amenazas T01-T20. Las exportaciones fueron revisadas visualmente el 13 de octubre de 2026 en la versión web 2.6.2-latest. El validador de esquema, referencias y paridad STRIDE complementa la revisión visual [R3].

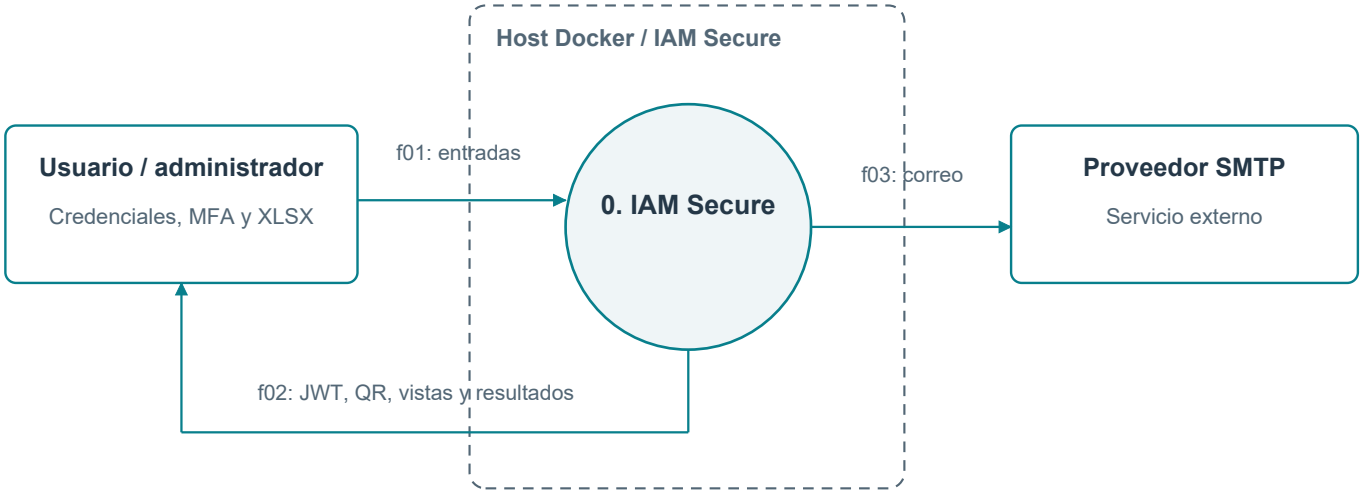


Figura 5. DFD nivel 0, redibujo vectorial del export de Threat Dragon [R3]. Se conserva proceso 0, entidades externas, flujos f01-f03 y límite Docker; no se añaden componentes.

Límite / activo	Implicación de seguridad
Navegador / APIs	Identidad, sesión, compañía y permiso deben comprobarse en servidor. El almacenamiento de sesión y el canal entre ventanas afectan T09/T18.
Host Docker / PostgreSQL	La red interna y las capacidades del contenedor no sustituyen TLS ni roles DB mínimos. Secretos y datos personales son activos, no valores del diagrama.
SMTP externo	STARTTLS implementado; la entrega de contraseña temporal y la falta de atomicidad con DB conservan limitaciones.
Cadena de suministro	Git, dependencias, runners e imágenes forman el alcance de T16 y los controles SAST/SCA/escaneo de imágenes.

3.2 DFD nivel 1 y persistencia lógica

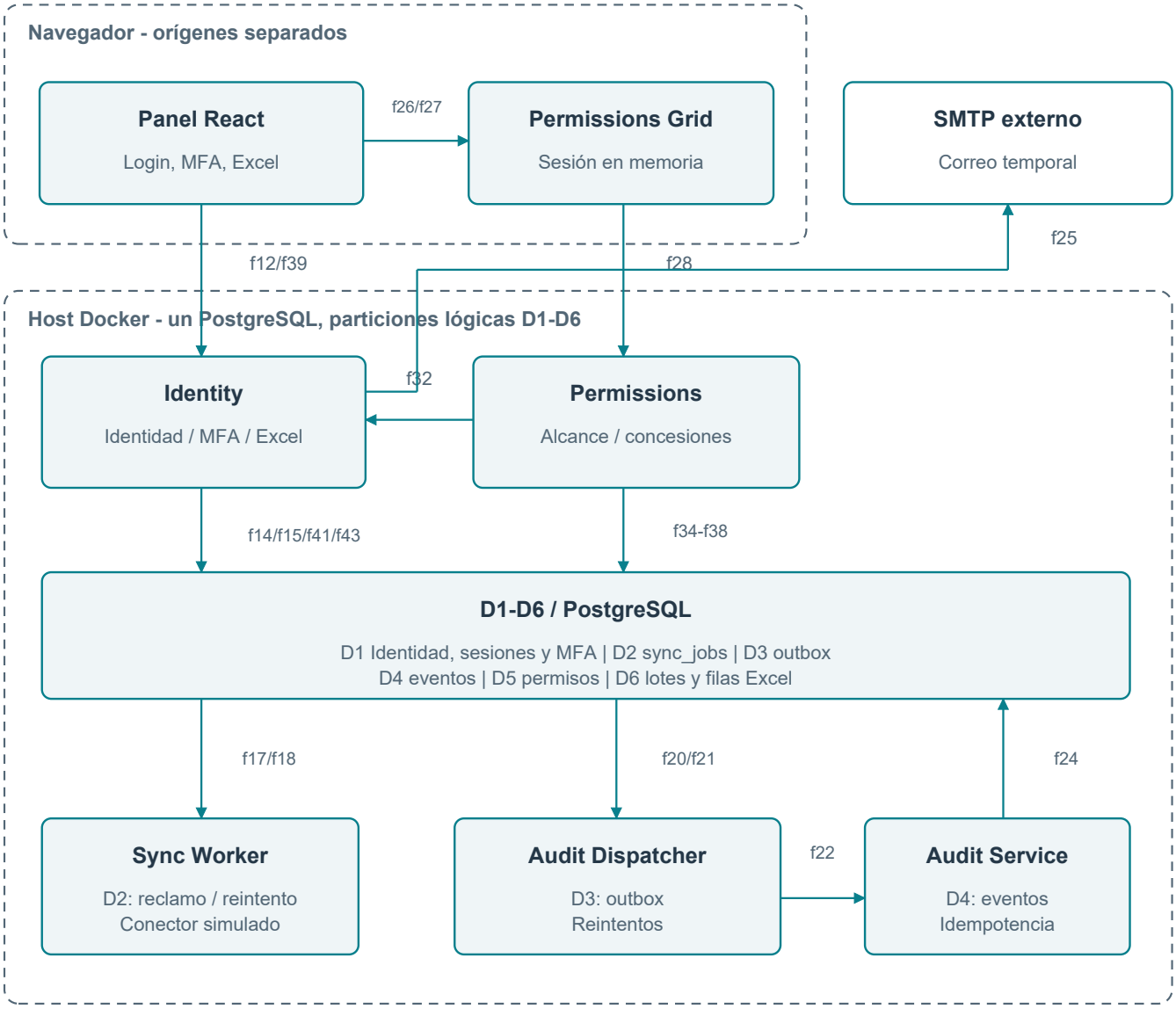


Figura 6. Vista sintética del DFD nivel 1 para lectura impresa. Fuente: modelo y export originales [R3]. Se agrupan D1-D6; los identificadores f representan flujos del modelo. El SVG original conserva todas las rutas y cruces.

Panel y grilla se ejecutan en el navegador y son distribuidos por Nginx. El canal postMessage verifica origen, ventana, nonce y expiración; no se representa como HTTP cifrado. Permissions consulta /auth/me y DB; Identity escribe permisos iniciales y lotes sin añadir un servicio Excel.

D1: identidad/sesiones/MFA/compañías; D2: sync_jobs; D3: auditoria_outbox; D4: auditoria_eventos; D5: permisos; D6: cargas y filas. Todos comparten PostgreSQL. El bootstrap es puntual y el conector Sync es simulado.

3.3 Inventario STRIDE: T01-T10

La severidad es la valoración del modelo, no un resultado de explotación. S: suplantación; T: manipulación; R: repudio; I: divulgación; D: denegación de servicio; E: elevación de privilegio. Los estados y decisiones se contrastaron con la aceptación humana [R3].

ID	Cat.	Amenaza	Sev.	Estado / residual
T01	S	Suplantación por robo de JWT	Alta	Open / aceptado local
T02	S	Suplantación del dispatcher	Alta	Open / aceptado local
T03	T	Alteración del tráfico HTTP	Alta	Open / no aceptado
T04	T	Manipulación de trabajos por acceso DB	Alta	Open / no aceptado
T05	R	Borrado de auditoría por acceso privilegiado	Alta	Open / aceptado local
T06	R	Pérdida de trazabilidad de operaciones	Media	Open / no aceptado
T07	I	Exposición de secretos MFA y datos personales	Alta	Open / no aceptado
T08	I	Contraseña temporal en buzón	Alta	Open / aceptado local
T09	I	Robo de sesión por XSS	Alta	Open / aceptado local
T10	D	Agotamiento por login y MFA	Alta	Open / no aceptado

Aceptación con alcance limitado

Aceptar riesgo residual para la entrega académica/local no elimina la amenaza ni equivale a aprobación productiva. Una ejecución CI aprobada no cierra amenazas automáticamente.

3.4 Inventario STRIDE: T11-T20

ID	Cat.	Amenaza	Sev.	Estado / residual
T11	D	Acumulación de outbox por caída de Audit	Media	Open / aceptado local
T12	D	Trabajos abandonados / concurrencia	Media	Open / aceptado local
T13	E	Escalada entre roles o compañías	Alta	Mitigated / aceptado local
T14	E	Privilegios excesivos de servicios DB	Alta	Open / no aceptado
T15	E	Intento de restablecimiento MFA fuera de jerarquía/compañía	Alta	Mitigated / aceptado local
T16	T	Dependencias o imágenes comprometidas	Alta	Open / aceptado local
T17	E	Manipulación de permisos entre compañías/usuarios	Alta	Open / aceptado local
T18	S	Suplantación del canal panel↔permissions-grid	Alta	Open / aceptado local
T19	T	Manipulación de XLSX	Alta	Open / aceptado local
T20	D	Abuso de carga masiva	Alta	Open / aceptado local

T13: RBAC/multitenancy y pérdida inmediata de alcance, con 92 pruebas específicas. T15: jerarquía/compañía y revocación, con 29 pruebas. E18 conserva la validación local y la aceptación humana posterior. El CI f87243e repitió las 121 pruebas específicas con PostgreSQL efímero [R4, R13].

T13 trata administración de identidad; T17 trata concesiones de vistas. T09 se refiere a XSS; T18 al canal entre ventanas. T10 cubre login/MFA; T20 parsing/aprovisionamiento masivo. Estas distinciones evitan atribuir un control a amenazas diferentes.

3.5 Riesgo residual y tratamientos prioritarios

Grupo	Total	Decisión vigente
Mitigación técnica verificada	2	T13/T15: Mitigated; riesgo residual aceptado solo para alcance académico/local.
Open con riesgo aceptado local	12	T01/T02/T05/T08/T09/T11/T12/T16/T17/T18/T19/T20; mantienen limitaciones.
Open con riesgo no aceptado	6	T03/T04/T06/T07/T10/T14; tratamiento pendiente.

Riesgo no aceptado	Tratamiento propuesto y verificación requerida
T03 - tráfico HTTP	Implementar TLS y verificar terminación/orígenes; repetir autenticación, sesión y pruebas de exposición.
T04/T14 - privilegios DB	Separar roles por servicio y limitar permisos; probar operaciones permitidas y denegadas sobre colas, identidad y auditoría.
T06 - trazabilidad	Revisar atomicidad del evento MFA post-COMMIT y alertas de entrega; probar fallos de DB/dispatcher sin perder trazabilidad.
T07 - secretos y PII	Separación/rotación de secretos y backups cifrados; comprobar accesos, restauración y protección de datos.
T10 - login/MFA	Rate limit previo y pruebas de carga/concurrencia; verificar límites antes del trabajo costoso y condiciones de bloqueo.

Los tratamientos anteriores son pendientes, no controles ya instalados. Los controles parciales de T20 no limitan todo el consumo anterior al parsing; la cuota actual no debe presentarse como protección integral de disponibilidad.

4. Pipeline DevSecOps

4.1 Integración continua y políticas de bloqueo

GitHub Actions ejecuta controles sobre push/PR y permite disparo manual o reutilización por CD. El espejo de yeisonfblopez permitió continuar las ejecuciones frente a las restricciones de Actions del repositorio principal. El código se sincroniza; los resultados remotos se atribuyen al repositorio ejecutor [R6, R7].

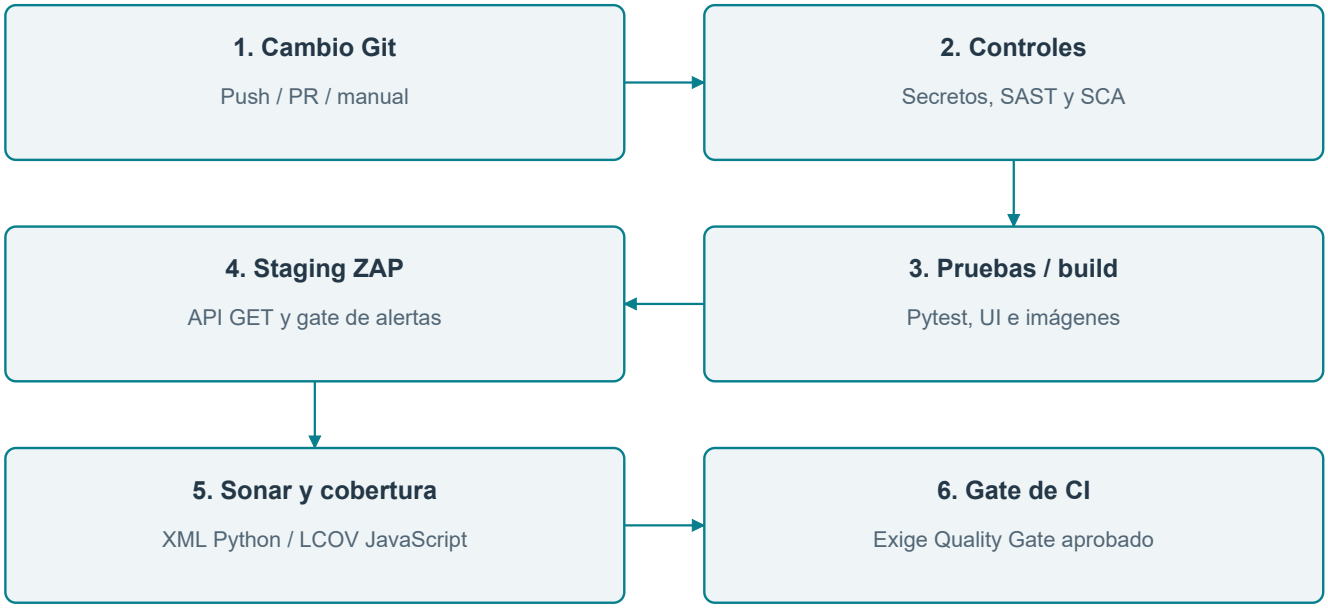


Figura 7. Dependencias lógicas del CI directo del espejo: controles y pruebas/build/staging ejecutan en paralelo; Sonar consolida cobertura de sus jobs, espera el Quality Gate y el gate final exige su aprobación. Los callers reutilizables de CD omiten Sonar explícitamente.

Control	Función / criterio
Gitleaks / Semgrep / Bandit	Secretos e historial; reglas de código y Python. Semgrep se ejecuta en Docker. Un fallo impide aprobar los controles requeridos.
SCA de dependencias	pip-audit/npm audit y Trivy de manifiestos/locks. Trivy SCA bloquea HIGH/CRITICAL, incluidas CVEs sin corrección.
Tests / frontend / modelos	Pytest, PostgreSQL aislado, UI Chromium, lint, configuración CSP y validación Threat Dragon. Los alcances son distintos.
Build y Trivy de imágenes	Construcción de imágenes y bloqueo CRITICAL. La prueba negativa de política no se interpreta como despliegue inseguro real.

4.2 ZAP automatizado y Quality Gate Sonar

El job zap-staging del espejo construye Identity, Permissions y Audit desde el checkout, en un proyecto nuevo, con DB iam_zap y secretos efímeros. No utiliza .env local, usuarios reales, SMTP ni Compose normal. No publica puertos de host [R6].

Etapa ZAP	Control verificado
Aislamiento previo	Contratos GET filtrados, rutas/métodos permitidos y gateway de alcance. El scanner no accede directamente a las APIs ni a DB.
Ejecución	7 scans; 39 operaciones/API-rol; 5 reglas activas LOW. Sin spider ni AJAX spider, con sesiones sintéticas.
Gate y completitud	MEDIUM/HIGH bloqueantes, sin alertas ignoradas. Se exige finalización por operación/rol/regla y acceso positivo a la aplicación.
Base y limpieza	Comparación de DB: solo actividad de sesión esperada. Limpieza del proyecto propio y paso always de respaldo; no docker prune global.
Reportes	HTML/JSON saneados, cobertura, gate y ciclo de ejecución; artefacto 30 días y evidencia seleccionada versionada con hashes.

Sonar actual: Quality Gate aprobado

El análisis f87243e aprobó todas las condiciones: nueva cobertura 88,1 % (mínimo 80 %), global 54,5 %, nueva duplicación 0 % y ratings A. No se cambiaron umbrales, periodo ni decisiones de issues. El check informa 43 issues nuevos y cero aceptados; el gate aprobado no elimina toda la deuda técnica [R13].

El CI combina datos propios de esta ejecución y genera XML Python portable y LCOV de cuatro módulos JavaScript. Mide 50 archivos Python e instrumenta 14 scripts de host del staging; no afirma cobertura de todos los procesos Docker ni de todo React. Las seis vulnerabilidades nuevas de instalación CI se corrigieron con wheels, locks completos y hashes (S8541/S8544). Sonar conserva el recibo del análisis y las métricas [R13].

4.3 Publicación y despliegue simulado

La publicación histórica 1.0.0 construyó y escaneó imágenes antes de push y verificó tags/descargas por digest. El despliegue simulado usa Ansible y Compose sobre imágenes fijadas por digest; Checkov y políticas complementan las comprobaciones runtime [R7].

Evidencia	Resultado y límite
Docker Hub 1.0.0	Run 37574847806: 29 trabajos y 14 tags push/pull verificados. No representa automáticamente todos los cambios actuales.
Deploy del espejo	Run 38502831730: 30/30, commit 8262da2. Despliega la release histórica 1.0.0.
IaC / runtime	Checkov con fixture negativa; 8 contenedores no root, HTTP y políticas runtime verificados. PostgreSQL sin puerto host en la simulación.
Idempotencia / persistencia	Segunda ejecución Ansible changed=0 y persistencia comprobada tras recrear PostgreSQL del entorno de prueba.
Instalación limpia	Segundo equipo iMac Intel: fuente 6d7e51c, secretos nuevos, build 7/7, migraciones, MFA, SMTP real, soporte y grilla. Corte independiente [R9].

Las aplicaciones locales se reconstruyeron y el usuario confirmó funcionamiento. La sincronización histórica d6c3440 preservó configuración, PostgreSQL, conteos agregados y contenedores; cinco HTTP aprobaron [R10]. La mejora actual modifica pruebas, tooling, CI y documentos; mantiene el código de aplicación, Compose y migraciones. No se publicó una nueva release Docker.

> **Reproducibilidad y entorno real**
>
> Build, instalación limpia, publicación y despliegue son evidencias diferentes. Un build no prueba SMTP real; un CD con 1.0.0 no despliega los cambios posteriores; una simulación sin TLS/HA no constituye producción real.

5. Resultados y tabla de hallazgos

5.1 Resultados cuantitativos y procedencia

Evaluación	Resultado	Alcance / referencia
CI del espejo	31/31 aprobados	f87243e; run 38587861186. Incluye ZAP, consolidación de cobertura, Sonar y gate [R11, R13].
Sonar externo	Quality Gate passed	Nueva 88,1 % >= 80 %; global 54,5 %. Todas las condiciones OK; 43 issues nuevos y cero aceptados [R12, R13].
ZAP final	7 scans / 39 API-rol / 1.947 solicitudes	0 hallazgos registrados; GET-only, 5 reglas LOW. DB sin cambios inesperados y limpieza confirmada [R6].
T13/T15 y Excel	121 seguridad + 86 Excel en CI	PostgreSQL efímero f87243e. E18 conserva 245 pruebas locales T13/T15/regresión en su propio corte [R4, R13].
Cobertura medida CI	Python: 78,12 % líneas / 74,80 % con ramas	50 archivos. JavaScript LCOV: 95,80 % líneas / 92,06 % ramas en cuatro módulos. Sonar global 54,5 % [R13].
SCA preservado	10/10 manifiestos; 2 MEDIUM	E24 sobre 8262da2: gate HIGH/CRITICAL aprobado. No se atribuye este conteo a d6c3440 [R8].
CD del espejo	30/30; changed=0	8262da2; release 1.0.0 por digest. No nueva release [R7].
Threat Dragon	20 amenazas	2 Mitigated y 18 Open: 12 con aceptación local y 6 no aceptadas [R3].
Instalación independiente	Build 7/7 y recorrido funcional	iMac Intel, 6d7e51c; secretos/base nuevos, SMTP real y persistencia [R9].

Las cifras de suites, cobertura, jobs y requests miden cosas distintas. No se suman pruebas históricas y actuales como si fueran una suite única; cero alertas ZAP no equivale a cero amenazas STRIDE.

5.2 Hallazgos de calidad y riesgos no aceptados

La tabla distingue observaciones de herramientas y riesgos del modelo. Prioridad de tratamiento no implica explotación demostrada. Las severidades Alta/Media proceden de STRIDE; Sonar y las brechas de entrega se expresan por su criterio propio.

ID / tipo	Hallazgo y evidencia	Severidad / estado	Tratamiento
H01 / calidad	Sonar nueva 88,1 % frente a 80 % mínimo; análisis y check aprobados [R13].	Cerrado en f87243e	Mantener reportes propios de cada revisión y exigir el gate, sin bajar umbrales.
H02 / T03	Tráfico HTTP local sin TLS acreditado [R2, R3].	Alta / no aceptado	TLS y verificación de exposición, CORS/orígenes y autenticación.
H03 / T04 + T14	Acceso DB con privilegios amplios/compartidos [R3].	Alta / no aceptado	Roles DB mínimos por servicio; pruebas de autorización sobre tablas y colas.
H04 / T06	Evento MFA de /auth registrado post-COMMIT; riesgo de trazabilidad [R3, R4].	Media / no aceptado	Atomicidad/outbox y fallos de entrega; observación de pendientes.
H05 / T07	Secretos MFA y PII: separación y backups cifrados pendientes [R3].	Alta / no aceptado	Secretos/roles/backup y recuperación verificada.
H06 / T10	Rate limit de infraestructura y carga login/MFA pendientes [R3].	Alta / no aceptado	Límites previos, concurrencia y pruebas de disponibilidad.

H03 agrupa dos amenazas para evitar repetir el mismo tratamiento DB. No se confunden estos riesgos con alertas ZAP: el escaneo final no registró hallazgos en su alcance.

5.3 Hallazgos de alcance y deuda de cierre

ID / tipo	Observación	Estado y acción
H07 / SCA histórico	E24 conserva 2 MEDIUM sin bloqueantes HIGH/CRITICAL; corresponde a 10 manifiestos de ese corte [R8].	Revisar/actualizar tooling y advisories, manteniendo trazabilidad. No afirmar cero CVEs globales ni conteos actuales sin su reporte.
H08 / límite DAST	ZAP usa sesiones sintéticas y GET-only: no login/MFA, carga XLSX, POST/PUT/PATCH/DELETE ni descubrimiento frontend [R6].	Ampliar escenarios en laboratorio autorizado y con datos sintéticos. Las respuestas 403 y los rechazos del gateway no prueban lógica protegida.
H09 / release	Docker Hub 1.0.0 no contiene todos los cambios actuales [R7].	Decidir nueva versión; construir, escanear, publicar y validar el despliegue de esa versión.
H10 / cobertura global	Sonar global 54,5 %. Python CI 78,12 % de líneas; LCOV de cuatro módulos. E22 conserva 69 % local histórico [R5, R13].	Ampliar cobertura global y React. Separar cada métrica, revisión y alcance; 88,1 % nueva no equivale a 88,1 % de todo el proyecto.
H11 / entrega	Repositorios privados, capturas finales y video de 10-15 minutos pendientes [R1].	Resolver acceso para evaluación, preparar historia funcional y grabar sustentación. Este PDF consolida el informe técnico; no reemplaza el video.

Interpretación del resultado de ZAP

0 alertas en 1.947 requests es el resultado del laboratorio f87243e definido. No elimina T09/T17/T18/T19/T20 ni demuestra ausencia de vulnerabilidades en flujos no ejecutados. Las seis instalaciones CI corregidas son distintas de los seis riesgos STRIDE no aceptados.

La aceptación humana mantiene 12 amenazas Open con riesgo aceptado únicamente para alcance académico/local. T13/T15 tienen tratamiento técnico verificado; T03/T04/T06/T07/T10/T14 no cuentan con aceptación residual. La aprobación CI no modifica esa decisión.

5.4 Cobertura, integridad y evidencias consultadas

Servicio Python	Cobertura local	Sin cubrir / sentencias
Identity	64 %	778 / 2137
Permissions	96 %	7 / 170
Audit Service	86 %	25 / 178
Audit Dispatcher	77 %	41 / 176
Sync Worker	78 %	38 / 169

E22: cobertura local histórica de sentencias de cinco servicios. No mide ramas/frontend ni incorpora el SHA original; no se usa para acreditar el cierre remoto [R5]. E29 conserva XML y LCOV del run actual y sus hashes: Python 78,12 % de líneas, 74,80 % con ramas; cuatro módulos JavaScript 95,80 % líneas/92,06 % ramas. Sonar usa su propio periodo: nueva 88,1 %, global 54,5 %.

Ref.	Documento / evidencia de origen
R1	README y requisitos
R2	Arquitectura y cuatro UML
R3	Threat Dragon, DFD y decisión STRIDE
R4	E18: integración local T13/T15
R5	Cobertura local y límites
R6	E26: ZAP y resultados CI/Sonar
R7	CI/CD del espejo y release histórico
R8	SCA: reportes preservados
R9	Instalación limpia en segundo equipo
R13	E29: cobertura remota, gate, recibo y hashes

R10. Recibo local histórico ZAP_Y_SINCRONIZACION_LOCAL_2026-10-13.json: d6c3440, cinco HTTP y datos/configuración preservados. R11. CI actual y artefacto ZAP: f87243e, gate y limpieza verificados. R12. Check Sonar aprobado: Quality Gate passed para el mismo commit.

El código y las evidencias anteriores se enlazan al corte f87243e. E29 se consulta en master porque se archiva con esta edición; su recibo identifica exactamente el análisis f87243e. E26/E27/E28 conservan históricos. Los repositorios privados requieren acceso del evaluador. No se incluyen credenciales, semillas MFA, JWT ni datos personales de usuarios.

6. Conclusiones

6.1 Balance técnico

IAM Secure implementa una base funcional de gobierno de identidades y accesos: autentica con contraseña y MFA, conserva sesiones revocables y aplica roles y compañía en servidor. Permissions separa concesiones de vistas, y la carga Excel reutiliza el aprovisionamiento con validación previa y resultados persistidos.

El ciclo DevSecOps acredita controles de secretos, SAST, SCA, pruebas, construcción e imágenes e IaC/CD simulado con evidencias propias. f87243e aprobó los 31 trabajos CI y el Quality Gate de Sonar. ZAP automatizado validó 7 scans, 39 operaciones/API-rol y 1.947 solicitudes, sin alertas en ese alcance y con limpieza confirmada.

El resultado exige interpretación por alcance. Las pruebas locales T13/T15 verificaron controles concretos; la instalación independiente demuestra reproducibilidad del corte ejecutado; el despliegue 1.0.0 no representa automáticamente la aplicación actual. El escaneo GET-only no cubre todas las funciones ni sustituye la decisión de riesgo STRIDE.

El bloqueo de cobertura nueva de Sonar quedó cerrado: 88,1 % frente a 80 % mínimo, con umbrales y periodo preservados. Las seis instalaciones CI nuevas se corrigieron con locks, hashes y wheels. La cobertura global Sonar 54,5 %, los 43 issues nuevos informados y los seis riesgos STRIDE no aceptados mantienen trabajo adicional. El gate aprobado acredita su política concreta, no ausencia global de vulnerabilidades.

6.2 Cierre priorizado y alcance de la entrega

Prioridad	Siguiente acción y criterio de cierre
1. Riesgo no aceptado	Tratar T03/T04/T06/T07/T10/T14 con controles y pruebas; registrar decisión residual humana posterior.
2. Calidad remota	Mantener el Quality Gate aprobado por revisión; ampliar cobertura global y componentes React y priorizar deuda técnica.
3. Release y alcance DAST	Validar nueva release si se publica; ampliar login/MFA, Excel, escritura y frontend en un laboratorio con alcance explícito.
4. Entrega académica	Resolver acceso al repositorio, completar capturas e historia funcional y grabar video. El informe técnico queda consolidado en este PDF.

La entrega constituye una solución académica/local trazable, con avances verificados y límites explícitos. Su transición a producción requiere los tratamientos pendientes, políticas operativas y validación del entorno destino; no se declara una plataforma productiva totalmente cerrada.